Lyn R. Hall

Cybersecurity & GRC Leader | Governance, Risk, Compliance, Business Continuity & Security Operations

Waldoboro, Maine · Remote · lynrhall1977-cyber.github.io/Portfolio

Cybersecurity and GRC leader with 12+ years in information security and 10+ years owning governance, risk, and compliance programs end to end. Carried CISO-level and director-level responsibilities without the title at two global SaaS companies, often as the only IT and security person in the department, and builds programs designed to run without a single point of failure. Coordinated multiple federal regulatory examinations as first-line owner, built a state agency's enterprise business continuity program before COVID-19 and then activated it in live production during the pandemic, and has owned SOC 2 Type II and PCI DSS audits solo. Builds AI governance under the NIST AI RMF and the EU AI Act, and builds working AI agents that turn reactive security work into scheduled, repeatable reporting. Writes the documents programs run on: policies, standards, plans, and SOPs, plus technical documents such as trust boundary overviews and diagrams.

SELECTED RESULTS

- **Built the security and GRC program from zero** at a PE-owned SaaS company, covering policy, controls, risk register, third-party risk, and AI governance, as sole owner and hands-on operator.
- **Coordinated multiple OCC regulatory examinations** as first-line owner and primary examiner point of contact.
- **Built an enterprise BC/DR program before COVID-19, then activated it in live production** during the pandemic, keeping a state agency running across facilities, systems, and a suddenly remote workforce.
- **Owned SOC 2 Type II and PCI DSS compliance** through full audit cycles as the sole compliance owner.
- **Raised on-time security awareness training completion from 67% to 87%** after one quarter and moved human and phishing risk from moderate to low.
- **Built a weekly cyber threat analysis agent** that compares CVEs with the company's tech stack, scores severity, and delivers remediation reports. It replaced a single CVE feed no one reviewed.
- **Built a custom incident scoring system** based on CISA's National Cyber Incident Scoring System (NCISS), with baseline, medium, and high/critical escalation tiers.
- **Consolidated the tech stack** and unified identity providers and mobile device management (MDM) platforms during a major acquisition.

WHERE I'VE BUILT PROGRAMS

NOV 2024 – PRESENT Global SaaS company, private equity–owned · Remote

Security Engineering Manager

Report to the CTO and the private equity firm's CISO; manage one direct report.

- Lead the SOC 2 Type I program build on a 67-task roadmap, starting with governance and a policy commitment reconciliation register.
- Own PCI DSS compliance (SAQ A), including the PCI DSS 4.0 future-dated requirements that became mandatory in March 2025.
- Deployed and tuned SentinelOne EDR and set up MDR coverage for macOS and Windows endpoints, where neither existed before.
- Wrote trust boundary overviews and diagrams for company products.
- Classified AI systems by EU AI Act risk tier and built AI policy and controls to meet its requirements and the NIST AI RMF.

- Built vCISO-style GRC and contingency-leader AI agents for drafting policies and standards, contingency planning, incident scoring, and suspicious-email investigation.

- Configured and rolled out Microsoft Intune for macOS and Windows. When Engineering pushed back on losing Time Machine backups, built a separate approved-exception policy for encrypted, company-owned USB backups, so a replacement laptop is working in 1–2 hours instead of a full day.
- Expanded SSO/SAML/SCIM to Google Workspace as the authoritative identity provider and configured MFA, data loss prevention (DLP), sharing restrictions, and alert center monitoring.
- Built user access reviews from scratch: identity provider to HRIS reconciliation, terminated-account cleanup, and management-confirmed privileged access reviews.
- Negotiated vendor contracts to secure more favorable pricing, saving 10–15% on average.
- Built a repeatable device procurement and lifecycle process; complete annual cyber insurance renewal questionnaires and pre-acquisition security due diligence.

APR 2021 – SEP 2024 Global SaaS company, acquired during tenure

IT Security & Compliance Manager

- Ran each annual audit cycle in 6–8 weeks: assigned evidence requests to control owners, held live evidence-collection sessions when requests stalled, and escalated to management only after that.
- Implemented SSO/SAML/SCIM on Microsoft Entra ID.
- Configured Thoropass and Scrut integrations with the identity provider and cloud providers to automate evidence collection, and mapped controls across frameworks to reuse evidence.
- Served as primary point of contact for enterprise security questionnaires, SIG questionnaires, customer due diligence, and RFP security response.
- Handled GDPR and CCPA requirements: customer data processing agreements, data subject requests, and privacy policies and notices.

- Brought HIPAA protected health information (PHI) security to audit readiness; the audit was dropped after the acquisition. Contributed to HITRUST certification planning with FDA 21 CFR Part 11 relevance.
- Supported FedRAMP and Canadian Protected B efforts at the coordination level, and reviewed NIST SP 800-171 for customers holding government contracts.
- Reviewed threat models and secure design with Engineering so security was built into the product during development.
- Coordinated on-premises and cloud penetration tests and tracked findings to closure; designed immutable and geo-redundant backups and ran restore tests.
- Managed PCI DSS vulnerability scanning in Qualys, documenting false positives and reporting risk-prioritized remediation to IT.
- Ran the KnowBe4 security awareness program and monthly role-based phishing campaigns, and won CFO approval for KnowBe4 PhishER by framing it as a headcount decision.
- Configured Microsoft Intune as the MDM platform for macOS and Windows, ran help desk, and built a repeatable device procurement and lifecycle process.
- Negotiated vendor contracts to secure more favorable pricing, saving 10–15% on average.
- Completed cyber insurance renewal questionnaires and pre-acquisition security due diligence; administered SharePoint, Salesforce (basic administration and access audits), and Jira.

MAY 2019 – APR 2021 State government agency · Maine

Business Continuity Planner

- Developed and tested the agency's enterprise business continuity and disaster recovery program before the COVID-19 pandemic.
- Led incident response at the coordination and decision-making level, including on-premises physical drills and virtual tabletop exercises.
- Conducted business impact analyses and risk assessments; designed and delivered preparedness training and tabletop exercises.
- Performed internal audits and control testing of IT systems, managed POA&Ms through remediation, and developed the agency's crisis communications plans.

JUL 2014 – MAY 2019 Federally regulated bank, OCC-supervised · Maine

Assistant Vice President of IT

- Owned IT and security end to end, including device management, IAM, help desk, and security awareness training with phishing simulations, with one direct report and a managed service provider (MSP).
- Built the bank's joiner/mover/leaver process to address OCC examiners' access-management concerns.
- Rewrote IT and security policies on NIST SP 800-53, replacing policies that followed no framework.
- Reported IT and security metrics to the board of directors, including joiner/mover/leaver time to completion.
- Managed third-party and vendor risk, served as primary point of contact for internal and external IT audits, and took part in pre-acquisition security due diligence.
- Owned or co-owned elements of the Bank Secrecy Act/anti-money laundering (BSA/AML) program and completed the FFIEC questionnaire.
- Coordinated penetration tests and tracked findings to closure; designed immutable and geo-redundant backups and ran restore tests.
- Built and tested BC/DR plans, and led physical security operations: access control, video surveillance, and guard and vendor management.

MAR 2010 – JUL 2014 Financial services firm · Maine

Quality Analyst

- Delivered quality assurance and quality-control review for financial-services client operations and coached staff.

WHAT I OWN

Technical & policy writing — Policies, standards, plans, and SOPs that are approval-ready; trust boundary overviews and diagrams; BC/DR and crisis communications plans

GRC program ownership — Zero-to-one program builds, SOC 2 Type I and Type II, PCI DSS 4.0, ISO 27001-aligned controls, cross-framework control mapping, continuous audit readiness

Regulatory examination & audit — OCC examinations, internal audits and control testing, evidence management, POA&Ms

Privacy & AI regulation — GDPR, CCPA, EU AI Act risk-tier classification, NIST AI RMF, AI acceptable-use policy and vendor AI evaluation

Business continuity & DR — Program design and testing, live production activation, business impact analysis, NIST SP 800-34, crisis communications, tabletop exercises, restore testing

Risk management — Risk register ownership, KRI/KPI development, NIST SP 800-37 RMF, third-party risk, SIG questionnaires, M&A security due diligence

Identity & access — SSO, SAML, and SCIM; joiner/mover/leaver processes; user and privileged access reviews

Security operations — Incident response leadership, EDR, MDR, vulnerability management, penetration test coordination, phishing simulation

Executive communication — Board reporting, customer due diligence, RFP security response

TECHNICAL SKILLS

Frameworks & regulations: SOC 2 Type I & II; PCI DSS v4.0.1 (SAQ A); NIST CSF; NIST SP 800-53; NIST SP 800-37 RMF; NIST SP 800-34; NIST AI RMF; EU AI Act; GDPR; CCPA; BSA/AML; ISO 27001-aligned (supported one certification through audit); NIST SP 800-171 (reviewed); HIPAA (readiness); HITRUST (planning); FFIEC (questionnaire); FedRAMP, CMMC, Canadian Protected B (coordination); Federal SSPs (team contributor)

Identity & access: SSO / SAML / SCIM; Microsoft Entra ID; Google Workspace admin security; Joiner/mover/leaver; Access certification reviews; Entra conditional access (working)

Endpoint & security tools: SentinelOne; Microsoft Intune (macOS & Windows); Microsoft Defender for Endpoint & Cloud; Qualys; KnowBe4 & PhishER; Webroot; Imperva

Infrastructure & recovery: Immutable & geo-redundant backup design; Azure Site Recovery (working); Veeam (working); VMware (working); Storage replication (working)

Cloud & automation: Microsoft Azure security; Custom AI agents; Google Workspace apps; Python (access review analysis); PowerShell (endpoint provisioning); GCP Security Command Center; AWS (working)

GRC & business platforms: OnSpring; Thoropass; Scrut; Jira; SharePoint; GitHub; Salesforce (basic administration)

EDUCATION AND CERTIFICATIONS

EDUCATION

Master of Science in Cybersecurity

University of Maine at Augusta · May 2022 · 4.0 GPA

Bachelor of Science in Computer Information Science

Concentration in Information Security · University of Maine at Augusta · May 2019 · 3.61 GPA, Dean's List (4 years)

CERTIFICATIONS

- Microsoft AZ-500, Azure Security Technologies
- Microsoft SC-900, Security, Compliance & Identity Fundamentals
- Certified OnSpring Administrator
- FEMA Professional Continuity Practitioner (Continuity Excellence Series, Level I)

ADDITIONAL CAPABILITIES BEYOND MY CURRENT ROLE

- **Physical security operations:** access control systems, CCTV and video surveillance, guard and vendor management
- **Large-scale BC/DR:** built a state agency's program before COVID-19, then led its live production activation and multi-facility coordination
- **Digital forensics and incident investigation:** root-cause and scope determination
- **Statistics and data analysis:** academic coursework foundation, applied occasionally throughout my career